

Confidence-Aware Guardrailed Agentic RAG for IoT Intrusion Mitigation Planning

[Open reproducibility package](#)

Joy Dutta, Samara Mayhoub, Hossien B. Eldeeb, and Ali Ismail Awad
Artifact version 1.0.0 | 23 August 2026

A self-contained handover from CICIoT2023 traffic observations to standards-grounded, deterministically bounded mitigation intent. The prototype is offline and does not execute network actions.

Contents

1. Purpose	3
2. System at a Glance	3
3. Research Questions	3
4. Repository Requirements	3
5. Installation	4
6. Dataset Acquisition and Integrity	4
7. Dataset Meaning and Label Construction	4
8. Leakage Control and Split Protocols	4
9. Detector and Calibration	5
10. Detector Sensitivity Checks	5
11. Fixed Agent Cases	5
12. Standards Corpus and Retrieval	6
13. Paired RAG/No-RAG Design	6
14. Proposal and Executor Schemas	6
15. Action Policy and Guardrails	6
16. Retrieval Relevance Audits	7
17. Wrong-Family and Action-Evidence Controls	7
18. Guardrail Mutation Stress Test	7
19. Detector-Error Propagation	8
20. API Cost Controls	8
21. Exact Execution Order	8
22. Canonical Run IDs	8
23. Main Results	9
24. Physical-World Interpretation	9
25. Limitations and Next Experiments	9
26. Troubleshooting	9
27. Verification Checklist	10

1. Purpose

This guide explains the complete offline proof of concept from the original CICIoT2023 traffic files to a bounded mitigation-intent object. It is written for a reader who did not participate in the implementation.

The practical question is: when a detector reports suspicious IoT traffic, can an agent prepare a response that is traceable to official guidance and kept inside deterministic safety limits?

The experiment does not connect to a live gateway. A final intent always has status `PROPOSED_NOT_EXECUTED`.

2. System at a Glance

The pipeline contains six functional stages:

1. A detector predicts one of eight broad traffic families.
2. A calibrated confidence score decides whether the alert may continue to planning or must be escalated.
3. A retriever finds three passages from seven official IoT-security documents.
4. an LLM proposes compact mitigation intent.
5. deterministic guardrails normalize scope, actions, parameters, approval, rollback, evidence, and execution status.
6. a second validator independently checks the full schema and action policy.

Action-specific evidence retrieval and conservative top-two-family filtering are evaluated as strengthening controls after the main paired experiment.

3. Research Questions

The saved experiment addresses eight questions:

- How sensitive is detector performance to the data-splitting assumption?
- Can calibrated confidence reduce the number of wrong alerts sent to planning?
- Does official-document RAG add traceable evidence compared with no RAG?
- Are the retrieved passages relevant to the predicted family?
- Does cited evidence support each recommended action?
- What deterministic value do the guardrails add beyond raw LLM output?
- What happens to planning actions when the detector predicts the wrong family?
- Do the declared safety invariants survive systematic proposal mutations?

4. Repository Requirements

The tested environment used Python 3.12.13 on Windows 11. The package requires Python 3.12 or newer to match the pinned numerical-library requirements. Exact library versions are in `requirements.lock.txt`.

The full detector path needs the official CICIoT2023 CSV archive and enough local storage for the 1.43 GB archive, extracted CSV files, prepared tables, and models. The API stages need an OpenAI account with access to the configured model and an `OPENAI_API_KEY` in the process environment.

The saved-result inspection and test paths need neither the dataset nor an API key.

5. Installation

Create and install a virtual environment:

```
[bash]
python -m venv .venv
python -m pip install --upgrade pip setuptools
python -m pip install -e ".[dev]"
python scripts/reproduce.py smoke
```

On Windows, use `.venv\Scripts\python.exe`. On macOS or Linux, use `.venv/bin/python` if the environment is not activated.

The smoke stage runs deterministic tests only. A successful release reports 13 or more passing tests, depending on later additions.

6. Dataset Acquisition and Integrity

Download the registered CICIoT2023 CSV archive from:

<<https://www.unb.ca/cic/datasets/iotdataset-2023.html>>

Save it as:

```
[text]
data/raw/CICIoT2023_CSV.zip
```

Expected integrity values:

```
[text]
Size: 1,430,268,604 bytes
SHA-256: E211E878D2F39226EA3A854683F91AE6175B628807EE96EEECB7A04A36A28DBD
```

Then run:

```
[bash]
python scripts/reproduce.py bootstrap
```

The script rejects a hash mismatch and performs path-safe extraction. It expects the extracted attack folders under `data/interim/CSV/`.

7. Dataset Meaning and Label Construction

The release contains 309 source CSV files, 46,776,700 rows, and 39 numerical features. A row is an aggregated network-traffic observation. It is not a complete incident and carries no verified device identity.

The folder name supplies one of 34 attack or benign types. The experiment maps these to Benign, BruteForce, DDoS, DoS, Mirai, Recon, Spoofing, and Web. The exact mapping is `reports/tables/attack_family_mapping.csv`.

The code samples at most 60,000 rows per broad family using seed 20260821 and removes duplicate feature vectors that would otherwise cross splits. Infinite values become missing values; model pipelines median-impute missing values.

The fixed prepared sample contains 378,527 rows.

8. Leakage Control and Split Protocols

The primary feature set removes `Number` and `Tot_sum`. These fields encode the aggregation window and can identify collection patterns associated with source folders. The all-feature model is reported only as an ablation.

Three split protocols expose different assumptions:

1. `stratified_rows` mixes rows from a source file across splits and serves as an optimistic reference.
2. `attack_type_aware` is the primary PoC protocol. All 34 attack types occur in train, calibration, and test. Source files are separated for types with at least three files; deterministic row blocks handle the remaining rare types.
3. `strict_family_file` holds out whole source files and acts as a difficult distribution-shift stress test.

The primary split has 221,795 training, 78,133 calibration, and 78,599 test rows. Test labels are not used to fit the model, calibrate scores, or select the confidence threshold.

9. Detector and Calibration

The primary detector is a class-balanced Random Forest with 140 trees, maximum depth 22, and minimum leaf size 2. It is fitted on training rows only. Sigmoid calibration is fitted on the separate calibration partition.

For N observations and K families, the multiclass Brier score used in the analysis is the mean squared difference between each predicted probability and the one-hot true-class indicator across all N by K entries. Negative log-likelihood is the mean negative logarithm of the probability assigned to the true family. Expected calibration error divides confidence into 15 bins and computes the count-weighted mean absolute gap between observed accuracy and mean confidence.

The threshold selection rule evaluates candidate confidence levels on the calibration set. It seeks selective accuracy of at least 0.95 with coverage of at least 0.25. If no candidate meets both, it chooses the highest selective accuracy and then the highest coverage. The selected threshold is applied once to the untouched test set.

Coverage is the fraction of rows eligible to continue to guardrailed planning. It is not the fraction of attacks mitigated.

10. Detector Sensitivity Checks

The detector evaluation includes:

- all 37 primary features versus all 39 source features;
- Random Forest versus Extra Trees and histogram gradient boosting;
- a hierarchical attack-versus-benign then family classifier;
- five fixed split/model seeds from 20260821 to 20260825;
- one global confidence threshold versus predicted-family thresholds.

These checks show whether the central observation depends on one unusually easy split, one model family, or one feature shortcut. They are not a test-set search for the highest possible score.

11. Fixed Agent Cases

The LLM experiment uses 32 fixed test cases, four per hidden true family:

- two confident correct detector predictions;
- one low-confidence correct prediction;
- the most confident detector error.

The LLM receives the predicted family, calibrated score, selected threshold, route, observed flow-profile scope, protocols, and selected numerical features. It does not receive the ground-truth family.

Nineteen cases continue to planning, nine are routed to escalation, and four predicted-benign cases continue to monitoring. Low-confidence responses are still generated for analysis, but deterministic policy keeps their operational route non-disruptive.

12. Standards Corpus and Retrieval

The seven-document corpus consists of NIST IR 8259A, NIST SP 800-213, NIST SP 800-213A, NIST SP 800-61 Rev. 3, ETSI EN 303 645 V3.1.3, RFC 8520, and RFC

8576. Official URLs, hashes, and packaging status are in

`docs/standards/manifest.json`.

PDF text is extracted with `pypdf`; RFC text is read as UTF-8. The corpus is split into 1,400-character chunks with 180-character overlap. TF-IDF over unigrams and bigrams returns the top three chunks. The query uses only the predicted family and observed protocols. The excerpt shown to the agent is centered on matched query terms.

The final corpus contains 666 chunks.

13. Paired RAG/No-RAG Design

The same 32 alerts are evaluated under both conditions. Model snapshot, prompt, compact schema, allowed actions, token limit, and case data remain the same. Task order is randomized with the fixed experiment seed.

The RAG condition receives three official excerpts and may copy their chunk identifiers. The no-RAG condition receives an empty context and must return an empty evidence list.

The main objective endpoint is whether the answer contains at least one valid identifier from the supplied context. Relevance and action support are audited separately so that a correctly formatted identifier is not mistaken for semantic grounding.

14. Proposal and Executor Schemas

The model returns a compact proposal with a recommended route, up to several action objects, rationales, and evidence identifiers. Non-strict structured output is intentional: it lets the experiment observe compact-schema failures and incompatible actions.

The deterministic full intent adds validated target scope, bounded duration, approval requirements, rollback, normalized parameters, validated evidence, and fixed non-execution status. `src/iot_poc/schemas.py` contains both schemas.

Raw full-schema validity is therefore expected to be zero when compact proposal fields are present but executor-only fields are absent. The important ablation is the measured transition from raw proposal to independently revalidated final intent.

15. Action Policy and Guardrails

`src/iot_poc/guardrails.py` defines compatible actions for every predicted family, disruptive action classification, duration and parameter bounds, fallbacks, and normalization.

The guardrails enforce these invariants:

- target scope comes from the validated alert;
- durations and numeric parameters remain bounded;

- disruptive actions require explicit approval and rollback;
- evidence identifiers must come from retrieved context;
- no more than three actions remain;
- uncertain routes remain non-disruptive;
- predicted-benign cases remain non-disruptive;
- the route is consistent with detector confidence;
- final status remains `PROPOSED_NOT_EXECUTED`.

The final object is validated again by `src/iot_poc/revalidate.py` rather than being accepted because the normalization function returned it.

16. Retrieval Relevance Audits

Sixteen cases, two per predicted family, contribute 48 top-three passages. The first semantic audit labels each passage direct, supporting, or irrelevant. A second model-based auditor receives the same passage and family without seeing the first label.

The report includes exact three-way agreement, Cohen's kappa, separate label counts, and a conservative relevant count accepted by both. The second audit is independent at the model-call level but is not described as a human assessment.

`reports/tables/retrieval_audit_blind_packet.csv` is available for an independent human assessment.

17. Wrong-Family and Action-Evidence Controls

The wrong-family control rotates each predicted family to a different family, retrieves official passages for that wrong family, and still tells the model it is in the ordinary RAG condition. This tests whether valid official formatting alone can produce an inflated grounding claim.

A blinded action-level auditor labels each action as directly supported, generally supported, or unsupported by cited excerpts. A paired exact McNemar test compares whether every action in the same case is supported under relevant and mismatched retrieval.

The action-specific binding stage retrieves two new passages for each final bounded action. It improves evidence support but leaves unsupported actions visible for review.

18. Guardrail Mutation Stress Test

Each of the 64 reference records is changed in nine systematic ways, creating 576 proposals:

- overbroad untrusted target;
- family-incompatible action;
- extreme numeric parameters;
- fabricated evidence identifier;
- excessive action count;
- missing action list;
- non-object output;
- low-confidence disruptive action;
- benign disruptive action.

The report records raw compact-schema validity, raw policy conformance, final schema and policy validity, invariant failures, and repair disposition counts for each mutation type. This is a deterministic contract test, not a live network attack test.

19. Detector-Error Propagation

Eight of the 32 agent cases are deliberately misclassified, creating 16 paired planning records across RAG and no RAG. The analysis compares the ordinary predicted-family policy with a conservative policy that keeps only actions compatible with both leading detector hypotheses.

The top-two rule represents a gateway that becomes cautious when two attack explanations are plausible. It can remove an unsuitable disruptive response at the cost of choosing monitoring or escalation instead of aggressive action.

20. API Cost Controls

`configs/experiment.json` records model names, token limits, per-stage call ceilings, estimated token use, and historical input/output prices.

The paired run is capped at 96 attempts and an estimated USD 2.00. The second relevance audit is capped at 10 calls and USD 0.25. The strengthening controls share a 50-call and USD 0.35 ceiling. A preflight estimate must fit under both the local and combined ceiling.

Successful records are appended immediately. Reusing a run ID resumes missing items. These controls limit estimated experiment use; researchers should also set appropriate account-level budgets because provider prices can change.

21. Exact Execution Order

```
[bash]
python scripts/reproduce.py smoke
python scripts/reproduce.py bootstrap
python scripts/reproduce.py offline
python scripts/reproduce.py agent --run-id paper_final_v2
python scripts/reproduce.py audits --audit-run-id second_relevance_audit_v2
python scripts/reproduce.py strengthening
python scripts/reproduce.py reports
python scripts/reproduce.py verify
```

The repository already contains the successful canonical API records. Running with their IDs resumes them and avoids repeated paid calls. Use a new ID for a new paired main experiment.

22. Canonical Run IDs

Run	Purpose
<code>paper_final_v2</code>	32 RAG and 32 no-RAG records
<code>second_relevance_audit_v2</code>	second relevance auditor
<code>shuffled_rag_control</code>	32 mismatched retrieval records
<code>action_evidence_faithfulness</code>	original versus mismatched action audit
<code>action_evidence_binding_audit</code>	final action-specific evidence audit

`paper_main`, `paper_final`, and `second_relevance_audit` are development provenance and do not feed the final analysis.

23. Main Results

The attack-type-aware detector averaged macro-F1 0.731 over five seeds. Global confidence routing averaged 96.2% selective accuracy at 54.0% coverage. In the selected run, the threshold was 0.85, with 52.1% test coverage and 96.5% selective accuracy.

RAG produced valid evidence in 31 of 32 cases; no RAG produced none. The conservative relevance result was 46 of 48 passages. Action-specific evidence binding supported 68.8% of final actions and left 31.3% unsupported.

Raw full-schema validity was 0 of 64 and raw action-policy conformance was 44 of

64. After deterministic normalization, all 64 passed the implemented full

schema and policy. All 576 normalized mutations passed the declared invariants.

In the 16 paired wrong-detector records, top-two filtering removed all three wrong-category disruptive cases and improved hidden true-family compatibility from 50.0% to 62.5%. Across all 64 records it reduced disruptive actions from 20 to four.

The final paired run used 64 successful calls at an estimated USD 0.1675. The strengthening package used 48 successful calls at an estimated USD 0.2383.

24. Physical-World Interpretation

A covered row means a gateway may prepare a bounded plan. An escalated row means the gateway collects more evidence and asks for review. Neither route executes a command in this implementation.

RAG gives an operator traceable official context. Guardrails prevent a model proposal from choosing an unvalidated target, unlimited duration, unsupported identifier, incompatible action, or execution-ready status. Action-specific binding asks a stricter question: whether each final action has evidence of its own.

The practical contribution is a controlled bridge from detector alert to reviewable mitigation intent. It is not autonomous attack suppression.

25. Limitations and Next Experiments

The difficult Web, Recon, BruteForce, Spoofing, and benign classes limit unconditional detector use. Strict whole-file distribution shift remains harder and more variable. Family-specific thresholds do not always reach the target.

Thirty-one percent of action-specific evidence judgments remain unsupported. An operational version should remove those actions, replace them with a bounded default, or require evidence review.

The present relevance audits are model-based. The prepared blind packet enables a genuinely independent human assessment without another API call.

The next materially stronger experiment is a contained gateway or network emulator measuring attack suppression, benign service impact, execution latency, and rollback success. CICIOT2023 alone cannot answer those questions.

26. Troubleshooting

Archive hash mismatch: confirm that the downloaded file is the official CSV archive and that it was not partially downloaded or renamed from another CICIOT2023 package.

ETSI download failure: download the exact URL in docs/standards/manifest.json, place the file at the recorded path, and rerun bootstrap. The hash check still applies.

Out-of-memory detector run: close other applications and run on a machine with more memory. A smaller sample is a different experimental condition, so record it in a separate configuration and use a new run ID.

API stage refuses to start: check `OPENAI_API_KEY`, model access, configured price estimates, existing run records, and the displayed call/cost ceiling.

27. Verification Checklist

- `python scripts/reproduce.py smoke` passes.
- dataset and standards hashes match their manifests.
- the main run has 32 RAG and 32 no-RAG successful records.
- every reported value points to a CSV or JSON file.
- no API key or local `.env` file is tracked.
- final intents remain `PROPOSED_NOT_EXECUTED`.

Run `python scripts/reproduce.py verify` for the automated portion of this checklist.